

La deuda silenciosa

Por qué un perfil Jr cubriendo QA + Ciberseguridad es viable y necesario

David Cabezas — VSC · 2026-04

Slide 1 · La pregunta correcta

No es:

"¿La IA reemplaza al QA?"

(Esa pregunta tiene respuesta técnica obvia — la IA acelera, pero no firma)

Es:

"¿Es viable que un solo perfil Jr cubra QA + Ciberseguridad operativa para nuestra escala?"

Mi respuesta basada en lo que ISO realmente exige: sí.

Slide 2 · El video que pasó José

Confirmado: Claude Code + Playwright es brutal. Lo probé.

Confirmado: lo metemos al pipeline en sprint 14 y 15.

Confirmado: vamos 10x más rápido en testing técnico.

Esto no es lo que está en discusión.

Lo que sigue es lo que la demo no muestra:

lo que pasa cuando llega el auditor de Goldfields a pedirnos los últimos 12 meses de releases firmados.

Slide 3 · El estado actual de VSC

```
3 proyectos en producción
~150 releases en últimos 12 meses
0 con test plan formal firmado
0 con aprobación de pase identificada
0 con segregación de funciones
540 días sin responsable designado
(Ley 21.663 Art. 8)
```

Cada release que se mergeó sin firma humana es una entrada en el log que no podremos auditar.

No es deuda técnica — es deuda regulatoria. Crece sola, no se va sola.

Slide 4 · Cómo audita ISO 9001 / 27001

El auditor **no certifica el futuro**. Certifica **lo que ya está operando**.

Te pide:

- Ticket del requerimiento → ¿existe?
- Código del feature → ¿está versionado?
- Test plan firmado → ¿quién y cuándo?
- Aprobación de pase a producción → **nombre de la persona**
- Segregación de funciones → autor ≠ aprobador
- Responsable de ciberseguridad → **nombre + designación formal**

Si no puedes mostrar esto para los últimos 12 meses, ni el certificado ISO ni el cumplimiento de Ley 21.663 avanzan.

Slide 5 · Las 3 cosas que pasan si aplicamos hoy

Opción A — Te bajan el alcance:

"Te certifico solo desde 2026". AMS queda fuera del alcance. Inservible para vender a Goldfields.

Opción B — Remediación retroactiva:

3-6 meses reconstruyendo papeleo. Auditor decente lo detecta como antedatado.

Opción C — Te rechazan:

6-12 meses operando "limpio" antes de re-aplicar. Pierdes licitaciones todo ese tiempo.

Las 3 son evitables si actuamos ahora.

Slide 6 · Lo que ISO realmente exige (no lo que asumimos)

ISO 27001 control A.5.3 — Segregación de Funciones:

"Las tareas y áreas de responsabilidad en conflicto deben estar segregadas."

ISO 27001 control A.6.1 — Roles y responsabilidades:

"La organización debe establecer y comunicar las responsabilidades y autoridades para los roles relevantes."

Ley 21.663 Art. 8:

"Las instituciones obligadas deberán contar con personal designado para la gestión de la ciberseguridad."

Ninguna dice "Senior". Ninguna dice "experto certificado". Dicen "rol designado, competente, segregado del autor del código".

Slide 7 · Por qué un Jr cubre ambos roles

Función	Quién la hace
Tests automatizados E2E	IA (Playwright + Claude)
Operar Test Plan template	QA & Cybersec Officer Jr
Firmar liberaciones	Jr (validador, no autor)
Operar reportes scanner Trivy/Gitleaks/Nuclei	Jr
Responder a ANCI ante incidentes	Jr designado
Pentest continuo con Nuclei + Burp	Jr sobre la pipeline ya armada
Threat modeling trimestral	CEO + Jr (sesión STRIDE)
Decisiones de arquitectura de seguridad	Documentadas en review de cada feature

Un solo Jr opera todo el día a día con los templates y la pipeline ya armadas.

Slide 8 · Lo que NO funciona — "cada dev con su IA"

Si Dev escribe código + configura IA + acepta resultado IA + aprueba merge:

= una sola entidad de responsabilidad

= No conformidad mayor en auditoría ISO 27001

La IA es la herramienta del dev. No una entidad independiente.

Para el auditor, sigue siendo el creador validándose a sí mismo.

El Jr rompe ese ciclo: él valida, no escribe el código. Eso es lo que ISO exige, no más.

Slide 9 · Mi propuesta concreta

QA & Cybersec Officer Jr — abril 2026

Un solo perfil cubriendo ambos roles operando los templates y la pipeline IA ya armadas.

Responsabilidades operacionales:

- Aplicar Test Plan template a cada release
- Firmar liberaciones (validador independiente)
- Operar reportes del qa-scanner (Trivy + Gitleaks + Nuclei)
- Responsable nominal de Ley 21.663 Art. 8
- Punto de contacto en auditorías
- Triage de vulnerabilidades + gestión del SGSI

Tiempo estimado de búsqueda: 30-45 días.

Time to ISO compliance una vez incorporado: 6-9 meses.

Slide 10 · Una semana típica del QA & Cybersec Jr

Diaria (lunes a viernes):

- 09:00 — Triage scanner (Trivy/Gitleaks/Nuclei)
- 09:30 — Standup con devs
- 10:00 — Tests E2E con Playwright + Claude
- 12:30 — Firma de liberaciones
- 14:30 — Documentación ISO

Foco por día (tarde):

| Día | Tarea |

|---|---|

Lun	Planning · backlog defectos
Mar	SGSI · políticas
Mié	Capacitación · catálogo
Jue	Auditoría interna
Vie	Reporte ejecutivo + métricas

Mensual: simulacro de incidentes · métricas SGSI

Trimestral: threat modeling STRIDE con CEO

Anual: auditoría externa ISO 27001

Carga total: ~40h/semana → full-time justificado

Slide 11 · La decisión que necesito de ti

Una pregunta concreta:

¿Abrimos la búsqueda de QA & Cybersec Officer Jr esta semana, o esperamos al cierre del próximo deal?

- **Sí** → publicación en LinkedIn / Get on Board / Trabajando.com en 7 días
 - **No** → asumimos formalmente que la deuda ISO sigue creciendo y que estamos en exposición continua a Ley 21.663
-

Slide 12 · Lo que NO te estoy pidiendo

- X Frenar la integración de Claude + Playwright (al contrario, la aceleramos)
- X Contratar dos roles separados (QA y Security)
- X Contratar a un experto Senior (un Jr sobre la pipeline IA ya armada cumple)
- X Empezar la certificación ISO mañana (es proceso de 6-9 meses)
- X Bajar la velocidad de desarrollo

Te estoy pidiendo abrir UNA búsqueda esta semana para un perfil Jr que cubra QA + Ciberseguridad operativa, supervisado técnicamente por mí.

Slide 13 · Cierre

La automatización con IA es nuestra ventaja — la mantenemos y la potenciamos.

Lo que falta es la firma humana que las normas ISO y la Ley 21.663 exigen, y que un perfil Jr operando los templates y la pipeline ya armadas puede entregar.

¿Vamos a operar otros 6 meses sin responsable designado, sabiendo que cada release suma deuda y cada día suma exposición legal?

¿O abrimos la búsqueda esta semana?

— **David Cabezas**, VSC